THEORY

Six ways a system can be attacked

Picture first, then the memorable analogy, then the precise exam explanation.

THE CENTRAL QUESTION

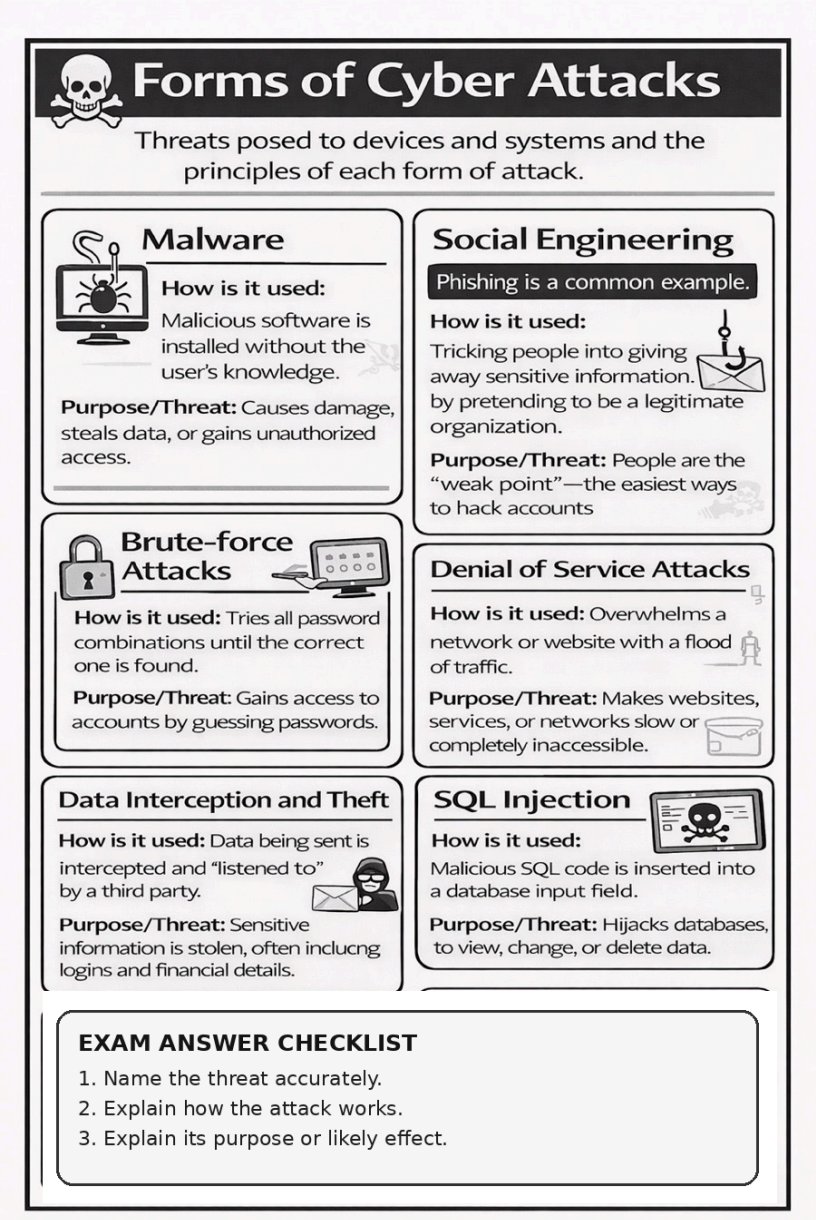
For each threat, explain how the attack happens and what the attacker wants or what harm is caused. That is the explicit OCR 1.4.1 requirement.

MALWARE	Malicious software that may steal, change or damage data.
SOCIAL ENGINEERING	Deceiving people into sharing information or taking unsafe actions.
BRUTE FORCE	Trying many credentials to guess a valid one.
DENIAL OF SERVICE	Making a service unavailable by overwhelming resources.
INTERCEPTION & THEFT	Capturing information during transmission.
SQL INJECTION	Abusing unsafe database input handling to change a query.

THEORY

Six cyber threats · illustrated

Study the six attacks using the illustrated examples. Then practise the precise explanation needed in an exam.



FROM IMAGE TO EXAM ANSWER

The illustration shows six different threats. For each one, explain how it works and what effect it may have.

THEORY

Three threats · people and passwords

Keep the existing illustration and analogies; always finish with the exam explanation.

MALWARE

Analogy: A computer catching a virus.

How: Malicious code is introduced onto a device, e.g. through an unsafe file or download.

Purpose / effect: It may steal information, damage files, spy on activity or disrupt use.

SOCIAL ENGINEERING / PHISHING

Analogy: Someone pretending to be trusted.

How: A message or page impersonates a trusted source to persuade someone to take an action.

Purpose / effect: A person may disclose credentials, send data or grant unauthorised access.

BRUTE-FORCE ATTACK

Analogy: Trying every key on a keyring.

How: Software repeatedly submits potential passwords or other credentials.

Purpose / effect: The attacker hopes to guess a valid login and access an account.

THEORY

Three threats · networks and databases

Explain what the attack changes and what its victim experiences.

DENIAL OF SERVICE

Analogy: Blocking a doorway so others cannot enter.

How: An attacker overwhelms a server or network service with traffic or requests.

Purpose / effect: Legitimate users cannot access the service or experience severe delays.

DATA INTERCEPTION & THEFT

Analogy: Listening in on a private conversation.

How: An unauthorised person captures data while it travels between devices.

Purpose / effect: Sensitive information such as credentials may be exposed or stolen.

SQL INJECTION

Analogy: A cheat code changing the rules - only a memory aid.

How: If application input is incorrectly combined into an SQL query, the intended query can be altered.

Purpose / effect: An attacker may obtain, change or delete database information.

KEY TERMINOLOGY

Key words for 1.4.1 · 1 of 2

Use the correct technical terms when explaining how each attack works and what it aims to achieve.

Malware

Software designed to perform harmful or unauthorised actions.

Virus

Malware that attaches to a host file or program and can spread when run.

Worm

Self-propagating malware which can spread between devices or networks.

Trojan

Malicious software disguised as something legitimate.

Ransomware

Malware that locks or encrypts access to data and demands payment.

Spyware

Software that secretly gathers information about activity or data.

KEY TERMINOLOGY

Key words for 1.4.1 · 2 of 2

Use the correct technical terms when explaining how each attack works and what it aims to achieve.

Social engineering

Manipulating people to reveal information or take unsafe actions.

Phishing

Deceptive messages or sites designed to steal information.

Brute force

Repeated systematic attempts to guess a password or secret.

DoS / DDoS

Overloading a service; distributed attacks use multiple sources.

Data interception

Capturing information during network transmission.

SQL injection

Untrusted input alters an application-generated SQL query.

WORKED EXAMPLES

Example 1 · A convincing school email

The central decision: does the attacker defeat software, or manipulate a person?

SCENARIO

A pupil receives a convincing message claiming to be from the school IT team. It asks them to confirm their password using a linked form.

STEP 1 · IDENTIFY THE ATTACK

This is phishing, an example of social engineering: the attacker impersonates a trusted sender.

STEP 2 · EXPLAIN HOW IT WORKS

The message may direct the pupil to a fake login page where credentials are entered and collected.

STEP 3 · STATE THE PURPOSE

The attacker wants account credentials and potentially unauthorised access to school data.

STEP 4 · COMPARE BRUTE FORCE

Brute force tries many possible passwords; phishing persuades a person to reveal one. Both may lead to compromised accounts.

WORKED EXAMPLES

Example 2 · A website under attack

The key skill: distinguish unavailability, intercepted data and a database query weakness.

SCENARIO

A school website suddenly stops responding. A separate report says confidential messages have been captured while travelling over the network.

DENIAL OF SERVICE

A flood of requests or traffic exhausts the service capacity, preventing legitimate access.

INTERCEPTION

Information is captured in transit. It may be read or stolen if it is not adequately protected.

SQL INJECTION

Unsafe database query construction allows input to alter the query, potentially exposing or modifying stored records.

LINKED EXAM ANSWER

Naming a threat is not enough. Explain how it is carried out, then give a linked purpose or effect. Do not describe these three as identical.

EXAM PRACTICE

Independent questions · 1 of 4

Answer before turning to the separate mark scheme. The original 12 questions remain unchanged; new coverage questions are clearly marked.

EXAM Q1 · 1 MARK

What is malware?

EXAM Q2 · 1 MARK

What is phishing?

EXAM Q3 · 1 MARK

What is a brute-force attack?

EXAM Q4 · 2 MARKS

State two examples of cyber attacks.

EXAM PRACTICE

Independent questions · 2 of 4

Use your own words. Explain the mechanism and purpose, not just the attack name.

EXAM Q5 · 2 MARKS

State two aims of a cyber attack.

EXAM Q6 · 3 MARKS

Explain how a brute- force attack works.

EXAM Q7 · 3 MARKS

Explain how phishing attacks work.

EXAM Q8 · 3 MARKS

Explain how a denial of service (DoS) attack affects a system.

EXAM PRACTICE

Independent questions · 3 of 4

Use your own words. Explain the mechanism and purpose, not just the attack name.

EXAM Q9 · 3 MARKS

Explain what is meant by data interception and theft.

EXAM Q10 · 4 MARKS

Describe two ways malware can harm a computer system.

EXAM Q11 · 4 MARKS

Describe two social engineering attacks.

EXAM Q12 · 6 MARKS

Explain why humans are often the weakest link in computer security.

EXAM PRACTICE

Independent questions · 4 of 4

Use your own words. Explain the mechanism and purpose, not just the attack name.

ADDED OCR COVERAGE · 3 MARKS

Explain the concept of SQL injection and state one possible purpose of the attack.

ADDED OCR COVERAGE · 3 MARKS

Explain the difference between a denial-of-service attack and data interception.

ANSWERS & MARK SCHEME

Model answers · 1 of 4

Indicative marking points. Match the meaning; exact wording is not always necessary.

EXAM Q1 · 1 MARK

What is malware?

Malware is software deliberately designed to carry out harmful or unauthorised actions on a system. (1)

EXAM Q2 · 1 MARK

What is phishing?

Phishing is a form of social engineering that uses deceptive messages or sites to trick a person into revealing information. (1)

EXAM Q3 · 1 MARK

What is a brute-force attack?

A brute-force attack repeatedly tries possible passwords or credentials to find the correct one. (1)

EXAM Q4 · 2 MARKS

State two examples of cyber attacks.

Any two: malware; phishing or social engineering; brute-force; denial of service; data interception and theft; SQL injection. (1 each, 2 maximum)

EXAM Q5 · 2 MARKS

State two aims of a cyber attack.

Any two: steal sensitive information; gain unauthorised access; disrupt a service; change/delete data; extort a victim. (1 each)

ANSWERS & MARK SCHEME

Model answers · 2 of 4

Indicative marking points. Match the meaning; exact wording is not always necessary.

EXAM Q6 · 3 MARKS

Explain how a brute- force attack works.

The attacker makes repeated guesses at a password (1), often using an automated program or systematic sequence (1), until a correct password is found and the account can be accessed (1).

EXAM Q7 · 3 MARKS

Explain how phishing attacks work.

An attacker sends a deceptive email or message that appears to come from a trusted person or organisation (1); it directs the person to a fake link/site or requests confidential information (1); the victim may reveal credentials or other private data (1).

EXAM Q8 · 3 MARKS

Explain how a denial of service (DoS) attack affects a system.

The attacker overwhelms a website, service or network with requests or traffic (1), using up its available capacity/resources (1), so legitimate users experience delays or cannot access it (1).

EXAM Q9 · 3 MARKS

Explain what is meant by data interception and theft.

Data is captured by an unauthorised party while it is being sent between devices (1); messages or packets can be read if not adequately protected (1); the captured confidential information may be stolen or misused (1).

ANSWERS & MARK SCHEME

Model answers · 3 of 4

Indicative marking points. Match the meaning; exact wording is not always necessary.

EXAM Q10 · 4 MARKS

Describe two ways malware can harm a computer system.

Any two harms, developed: malware can delete or corrupt important files, causing loss of work (up to 2); it can capture passwords or personal information, allowing identity theft or account compromise (up to 2). Award distinct valid mechanisms and effects to a maximum of 4.

EXAM Q11 · 4 MARKS

Describe two social engineering attacks.

Phishing: deceptive messages impersonate a trusted sender and entice a victim to reveal credentials or follow a false link (up to 2). Pharming: a victim is directed to a fraudulent website where information may be collected (up to 2). Award two distinct developed examples, such as pretexting or impersonation.

EXAM Q12 · 6 MARKS

Explain why humans are often the weakest link in computer security.

A developed response explains that attackers can impersonate trusted people or organisations (e.g. phishing); users may believe a convincing message, click a dangerous link or disclose credentials; social engineering bypasses technical barriers by exploiting human decisions; stolen credentials can enable account access or data theft; awareness and verification matter, but user errors are not the only source of vulnerabilities. Award up to 6 for relevant, linked points and clear explanation.

ANSWERS & MARK SCHEME

Model answers · 4 of 4

Indicative marking points. Match the meaning; exact wording is not always necessary.

ADDED QE1 · 3 MARKS

Explain the concept of SQL injection and state one possible purpose of the attack.

Untrusted text supplied to an application is improperly treated as part of a database query (1), changing the intended query behaviour (1), to access, change or delete data without authorisation (1).

ADDED QE2 · 3 MARKS

Explain the difference between a denial-of-service attack and data interception.

A denial-of-service attack floods or exhausts resources so legitimate users cannot access a service (1). Interception captures data during communication (1). Its purpose may be to discover confidential information, not necessarily to stop the service working (1).

THEORY

Seven ways to reduce cyber threats

Name the prevention method, explain what it does, and link it to the threat it limits.

THE EXAM RULE

Threat → Appropriate defence → How it works → Reduced risk. These seven common prevention methods are named by OCR. Some useful extra protections appear later but must not replace this list.

PENETRATION TESTING	An authorised tester simulates attacks to find weaknesses so they can be fixed.
ANTI-MALWARE SOFTWARE	Scans or monitors files/programs; can quarantine or remove identified malicious software.
FIREWALLS	Examines traffic against rules and permits or blocks selected network connections.
USER ACCESS LEVELS	Permissions restrict which users can access, change or delete particular resources.
PASSWORDS	Long, unique passwords make unauthorised account guessing more difficult.
ENCRYPTION	Transforms plaintext using a key so intercepted data is not readable without the key.
PHYSICAL SECURITY	Limits physical access to computers, cables, storage media and server rooms.

THEORY

Security defences and everyday analogies

Match each familiar security analogy to a specific defence and explain how it reduces risk.

Safety Tool	What it does (simple)	Like in real life
Anti-malware software	Finds and removes bad software	A **doctor** for your computer
User access levels	Only lets people do what they're allowed to do	Different **keys** for rooms
Strong passwords	Makes accounts hard to break into	A **strong lock**
Two-Factor Authentication (2FA)	Uses two checks to prove it's you	A lock **and** a code
User training	Teaches people how to stay safe	Learning **road safety**
Account lock-out policy	Locks accounts after too many wrong tries	A door that **locks itself**
Firewalls	Blocks bad traffic from the network	A **security guard**
Penetration testing	Finds weak spots before hackers do	A **friendly burglar**
Encryption	Scrambles messages so others can't read them	Writing in **secret code**
Input validation & sanitisation	Checks what people type to stop harm	A **safety checker**
Physical security	Protects computers in real life	**Locks, doors, CCTV**

STUDY THE COMPARISON TABLE

The analogy is a reminder, not a complete exam answer. A security guard suggests a firewall, but a firewall follows traffic rules rather than recognising every attack. Room keys suggest access levels, but those are software permissions. Secret code suggests encryption, which uses algorithms and keys.

SCOPE CHECK

OCR names seven core methods: penetration testing, anti-malware, firewalls, user access levels, passwords, encryption and physical security. Related measures include 2FA, training, account lockout and input checking.

THEORY

Four teaching analogies · access and detection

Picture → familiar comparison → exact action → the threat it limits.

PENETRATION TESTING

Teaching analogy: Friendly burglar

What it actually does: An authorised tester simulates attacks to find weaknesses so they can be fixed.

ANTI-MALWARE SOFTWARE

Teaching analogy: Doctor

What it actually does: Scans or monitors files/programs; can quarantine or remove identified malicious software.

FIREWALLS

Teaching analogy: Security guard

What it actually does: Examines traffic against rules and permits or blocks selected network connections.

USER ACCESS LEVELS

Teaching analogy: Different room keys

What it actually does: Permissions restrict which users can access, change or delete particular resources.

THEORY

Three teaching analogies · access, data, rooms

Explain the mechanism; avoid claiming any single defence guarantees security.

PASSWORDS

Teaching analogy: Strong lock

What it actually does: Long, unique passwords make unauthorised account guessing more difficult.

ENCRYPTION

Teaching analogy: Secret code

What it actually does: Transforms plaintext using a key so intercepted data is not readable without the key.

PHYSICAL SECURITY

Teaching analogy: Locked doors and CCTV

What it actually does: Limits physical access to computers, cables, storage media and server rooms.

USE SEVERAL DEFENCES

An encrypted school laptop can still be stolen. A locked server room does not prevent a phishing email. Defences cover different risks and work best in layers.

THEORY

Match each attack to a useful defence

An exam answer earns marks by naming the control and explaining how it limits the attack.

MALWARE

Anti-malware + access levels

Scan/quarantine malicious software; restrict installing or running unapproved programs.

PHISHING / SOCIAL ENGINEERING

Passwords + access levels

Unique secrets limit reuse; minimal permissions limit damage if credentials are stolen.

BRUTE FORCE

Strong passwords

Long, unpredictable passwords require far more guesses to find a valid login.

DENIAL OF SERVICE

Firewall rules + monitoring

Filter or restrict some unwanted traffic; a large-scale attack may still require other protections.

DATA INTERCEPTION

Encryption

Intercepted ciphertext is unintelligible without the appropriate key.

SQL INJECTION

Penetration testing + limited access

Testing can expose unsafe handling of database queries; low permissions limit damage. Parameterised queries fix the injection mechanism.

THEORY

Further security protections

These strengthen a security plan. They are supplementary to OCR's seven named prevention methods.

TWO-FACTOR AUTHENTICATION

Teaching analogy: A lock and a code

How it helps: Adds another verification factor when logging in.

USER TRAINING

Teaching analogy: Learning road safety

How it helps: Teaches users to notice suspicious messages and verify requests.

ACCOUNT LOCKOUT

Teaching analogy: A self-locking door

How it helps: Limits repeated failed login attempts.

INPUT HANDLING

Teaching analogy: Safety checker

How it helps: Validates input; safe parameterised queries prevent SQL query structure changes.

KEY TERMINOLOGY

Key words for 1.4.2 · 1 of 2

The yellow is the exact same translucent SVG highlighter used in classroom lessons.

Vulnerability

A weakness in a system that an attacker could exploit.

Penetration testing

An authorised attempt to expose system weaknesses using simulated attacks.

Anti-malware

Software that detects, quarantines or removes known malicious software.

Firewall

Software or hardware that controls traffic using security rules.

Access levels

Permissions determining the resources or actions a user can access.

Authentication

Process of checking a user or device is who it claims to be.

KEY TERMINOLOGY

Key words for 1.4.2 · 2 of 2

The yellow is the exact same translucent SVG highlighter used in classroom lessons.

Strong password

A long, unique secret difficult for an attacker to guess.

Encryption

Converting readable plaintext into ciphertext using a key and algorithm.

Physical security

Locks, access cards, surveillance and secure storage limiting physical access.

Two-factor authentication

Login checking two distinct types of evidence, e.g. password plus an authenticator.

Account lockout

Restricting login attempts after repeated failures to slow password guessing.

Defence in depth

Using several complementary protections so failure of one is less damaging.

WORKED EXAMPLES

Example 1 · A phishing message at school

Choose protections that address what is actually at risk.

SCENARIO

A teacher receives a fake IT-support email requesting account credentials. An attacker may then try to read confidential student files.

STEP 1 · IDENTIFY THE WEAKNESS

The attack tricks a person into revealing credentials. A stolen login might give access to confidential documents.

STEP 2 · CHOOSE AN OCR CONTROL

User access levels restrict which student records each account may open or change.

STEP 3 · EXPLAIN ITS EFFECT

Even if the teacher account is compromised, an attacker may be unable to view records outside that account’s permissions.

STEP 4 · ADD A COMPLEMENTARY CONTROL

Unique, strong passwords reduce guessing/reuse risks; staff training and 2FA provide useful additional layers.

WORKED EXAMPLES

Example 2 · A school exam portal

Write about the control’s mechanism rather than simply calling it secure.

SCENARIO

Exam data travels between staff laptops and a school server. The server also accepts uploads and database searches.

STEP 1 · INTERCEPTED DATA

Encryption protects the information in transit, so an interceptor without the key cannot read the contents.

STEP 2 · UNAUTHORISED NETWORK ACCESS

A firewall checks connections against rules and restricts unwanted network traffic. It does not stop every attack.

STEP 3 · SQL INJECTION RISK

Penetration testing can discover unsafe database handling. Parameterised queries prevent untrusted input changing SQL structure; this is a useful technical extension.

STEP 4 · LOST OR STOLEN DEVICES

Physical security limits access to machines; permissions and encryption help protect information if other controls fail.

EXAM PRACTICE

Practice questions · 1 of 4

Answer independently first; check the mark scheme afterwards.

EXAM Q1 · 1 MARK

What is a security vulnerability?

EXAM Q2 · 1 MARK

What is encryption used for?

EXAM Q3 · 1 MARK

What is a firewall?

EXAM Q4 · 2 MARKS

State two ways to prevent malware attacks.

EXAM PRACTICE

Practice questions · 2 of 4

Answer independently first; check the mark scheme afterwards.

EXAM Q5 · 2 MARKS

State two features of strong passwords.

EXAM Q6 · 3 MARKS

Explain how user access levels improve security.

EXAM Q7 · 3 MARKS

Explain how anti-malware software protects a system.

EXAM Q8 · 3 MARKS

Explain how account lockout policies prevent brute-force attacks.

EXAM PRACTICE

Practice questions · 3 of 4

Answer independently first; check the mark scheme afterwards.

EXAM Q9 · 3 MARKS

Explain how input validation helps prevent SQL injection.

EXAM Q10 · 4 MARKS

Describe two ways to prevent phishing attacks.

EXAM Q11 · 4 MARKS

Describe two ways firewalls help protect networks.

EXAM PRACTICE

EXAM Q12 + additional questions

Answer independently first; check the mark scheme afterwards.

EXAM Q12 · 6 MARKS

Explain how a range of security measures can be used to protect a computer system.

ADDED OCR COVERAGE E1 · 3 MARKS

Explain how an organisation could use penetration testing to reduce a security vulnerability.

ADDED OCR COVERAGE E2 · 3 MARKS

Explain how physical security and user access levels protect different weaknesses in a school.

ANSWERS & MARK SCHEME

Model answers · 1 of 4

Indicative points. Full credit depends on the quality of explanation, not memorising these exact sentences.

EXAM 1 · 1 MARK

What is a security vulnerability?

A vulnerability is a weakness in a computer, application or network that could be exploited by an attacker. (1)

EXAM 2 · 1 MARK

What is encryption used for?

Encryption converts readable data (plaintext) into unreadable ciphertext using an algorithm and key, protecting confidentiality if data is intercepted. (1)

EXAM 3 · 1 MARK

What is a firewall?

A firewall checks network traffic against security rules and allows or blocks connections. (1)

EXAM 4 · 2 MARKS

State two ways to prevent malware attacks.

Anti-malware software scans/detects potentially malicious programs (1), and software/security updates repair known weaknesses that malware might exploit (1).

ANSWERS & MARK SCHEME

Model answers · 2 of 4

Indicative points. Full credit depends on the quality of explanation, not memorising these exact sentences.

EXAM 5 · 2 MARKS

State two features of strong passwords.

Long enough to resist guessing (1) and unique/unpredictable rather than a common or reused password (1). Accept other justified features such as a suitable combination of character types.

EXAM 6 · 3 MARKS

Explain how user access levels improve security.

User permissions restrict who can see, change or delete information (1). A compromised account may have only limited access (1), reducing the possible harm to protected files or settings (1).

EXAM 7 · 3 MARKS

Explain how anti-malware software protects a system.

Anti-malware scans or monitors software for suspicious or known malicious patterns (1), identifies/quarantines threats to stop them running (1), and removes or isolates malicious software to reduce infection (1).

EXAM 8 · 3 MARKS

Explain how account lockout policies prevent brute-force attacks.

After a specified number of failed sign-ins, the system blocks/delays further attempts (1). This limits the speed of repeated guessing (1), reducing the effectiveness of brute-force attempts (1).

ANSWERS & MARK SCHEME

Model answers · 3 of 4

Indicative points. Full credit depends on the quality of explanation, not memorising these exact sentences.

EXAM 9 · 3 MARKS

Explain how input validation helps prevent SQL injection.

Validation checks data meets expected rules or format (1), rejecting or correcting unsuitable entries (1). However, validation alone is not a reliable SQL-injection defence: safely parameterised database queries keep untrusted data separate from SQL commands (1). Credit a clear supported explanation of the Practice question, not a false claim that all malicious input is detected.

EXAM 10 · 4 MARKS

Describe two ways to prevent phishing attacks.

Train users to spot suspicious messages and verify senders/links rather than disclosing credentials (up to 2). Two-factor authentication limits misuse of stolen passwords by requiring another independent factor (up to 2). Award two distinct developed approaches.

EXAM 11 · 4 MARKS

Describe two ways firewalls help protect networks.

A firewall can restrict incoming connections to allowed services and ports (up to 2). It can monitor/filter outgoing or incoming traffic against rules, blocking suspicious or unauthorised traffic (up to 2). Avoid the inaccurate idea that a firewall stops all attacks.

ANSWERS & MARK SCHEME

Model answers · 4 of 4

Indicative points. Full credit depends on the quality of explanation, not memorising these exact sentences.

EXAM 12 · 6 MARKS

Explain how a range of security measures can be used to protect a computer system.

Award up to six developed and linked points across several defences. For example, anti-malware identifies/quarantines infected files, firewalls restrict unauthorised traffic, access levels limit data access if an account is compromised, strong unique passwords reduce guessing, encryption protects intercepted data, and physical locks limit access to devices. Penetration testing identifies vulnerabilities so fixes can be applied. Credit explanations of how each method limits a named risk, not a mere list.

ADDED E1 · 3 MARKS

Explain how an organisation could use penetration testing to reduce a security vulnerability.

An authorised tester simulates realistic attacks (1), identifies weaknesses that could be exploited (1), and reports those weaknesses so the organisation can fix them before a real attacker exploits them (1).

ADDED E2 · 3 MARKS

Explain how physical security and user access levels protect different weaknesses in a school.

Physical security restricts who can reach devices or a server room (1). Access levels restrict what signed-in users can read or change (1). Together they address physical and account-based risks rather than relying on one barrier (1).